

ACTIVITY PACK

Activity 1: Readme

Activity 1 - Threat Modelling a Generative AI Concierge

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Readme

Activity 1 - Threat Modelling a Generative AI Concierge

Course: AI Security for Autonomous AI Agents **Course Code:** TGS-2025060473 | **TSC:** ICT-INT-0052-1.1 **Block:** Day 1 - Generative AI Security

At a glance

Duration	45 minutes
Format	Small groups of 3 - 4, plenary debrief
Type	Realistic synthetic simulation (SIM)
Learning Outcome	LO1
K/A statements assessed	K2, K3, A4

Purpose

Learners threat-model a fictional deployed hospitality GenAI concierge, identify trust boundaries and attacker-writable retrieval sources, turn each application mode into an attack surface, and make a rollout recommendation with costed controls.

Files in this folder

File	Audience	Use
SCENARIO.md	Learner	The case study narrative, artefacts and data
DISCUSSION-QUESTIONS.md	Learner	The five questions to work through in groups
SECURITY-CHECKLIST.md	Learner	Deployment evidence checklist for the concierge
Activity-1-*.pdf	Learner	Printable full learner pack including the checklist

How to run it

1. **Set up (5 min).** Form groups of 3 - 4. Issue SCENARIO.md and DISCUSSION-QUESTIONS.md. Trainer debrief notes are supplied separately and are not stored in the learner-facing Activities folder.
2. **Group work (30 minutes).** Groups work the five questions in order. Circulate; the questions are designed to be argued, not looked up.
3. **Presentation (5 minutes).** Each group presents its answer to one nominated question.
4. **Debrief (5 minutes).** Use the separate trainer notes to draw out the teaching points and correct recurring misconceptions.

Learner workflow

1. Inventory every channel, retrieval source, data store, model, tool and output consumer in the scenario.
2. Draw the data flow and mark each boundary where a public, partner or internal writer can place content into model context.
3. Mark personal data, secrets and business-sensitive data, including purpose, owner and retention.
4. Write one realistic abuse case for every attacker-writable source; do not test a live system.
5. Trace each abuse case from source through model interpretation, identity and tool authority to its possible effect.
6. Rank the boundaries by impact, likelihood, reversibility and detection difficulty.
7. Select the earliest deterministic control for the top three risks and record owner, test evidence, residual risk and operational cost.

8. Decide proceed, conditional proceed or halt, then complete SECURITY-CHECKLIST .md.

Required evidence

- One labelled data-flow diagram covering at least three channels, four retrieval sources and four tools.
- One ranked abuse-case table with a source-to-sink chain for every shortlisted risk.
- Three control decisions, each with an owner, evidence test, residual risk and operational cost.
- One rollout decision supported by the completed deployment checklist.

Acceptance criteria

The submission passes when every external writer, personal-data path and action tool is represented; the three priority risks can be traced end to end; and the rollout decision is supported by testable, owned controls rather than prompt wording alone.

The slide deck remains concept-led. These learner procedures are also reproduced in the Learner Guide.

Alignment

Every question in DISCUSSION-QUESTIONS .md is tagged with the K or A statement it evidences. This activity contributes to **LO1** and is assessed through the Written Assessment (SAQ) and the Case Study.

This material belongs to Tertiary Infotech Pte Ltd (UEN: 20120096W). All Rights Reserved.